VIRIATO

Relatório do Sistema

Controle de processos multi-empresa: como o sistema funciona, como foi construído e quais são seus limites atuais.

Versão do código	commit `f4f37be` (branch `claude/awesome-hopper-3on31d`)
Data	12 de novembro de 2026
Estágio	MVP funcional, ainda não preparado para produção
Repositório	github.com/monfredo18/Viriato

1. Visão geral

O Viriato é um sistema web para cadastrar, acompanhar e automatizar **processos** dentro de uma empresa. Cada processo percorre as **etapas** de um **fluxo** definido pela própria empresa, tem um responsável, um prazo por etapa, documentos anexados e um histórico completo do que aconteceu.

O sistema foi desenhado desde o início como **SaaS multi-empresa**: uma única instalação atende várias empresas, e os dados de uma nunca são visíveis para outra.

> **Em uma frase:** a empresa cadastra as empresas que atende, os setores e o que cada setor entrega; cada entrega tem um fluxo de etapas. Ao abrir um processo, escolhe-se a empresa atendida, o departamento, a entrega e o responsável, e o sistema controla em que etapa o processo está, quando vence o prazo e o que já foi feito.

O que o sistema faz hoje

- **Cadastro self-service de empresa:** quem se cadastra vira administrador e já recebe um fluxo padrão.
- **Usuários, setores e papéis:** Administrador, Gestor e Usuário, com permissões diferentes; cada funcionário pertence a um setor.
- **Cadastros:** empresas atendidas (com número e nome), setores e entregas. Cada setor define quais entregas faz, e cada entrega define o fluxo.
- **Fluxos configuráveis:** etapas com prazo em dias, etapa inicial e etapas finais.
- **Processos:** abertos com empresa, departamento, entrega e responsável; busca e filtros, movimentação entre etapas respeitando as regras do fluxo, atribuição, comentários e cancelamento.
- **Histórico:** cada ação fica registrada com autor, data e comentário.
- **Documentos:** upload e download de arquivos por processo, guardados no AWS S3.
- **Prazos e notificações:** aviso dentro do sistema (sininho) e por e-mail, com alerta automático de prazo vencendo ou vencido.
- **Relatórios em PDF:** lista dos processos com filtros por setor, responsável, empresa, período e situação, dentro do que o papel de cada pessoa permite.
- **Interface:** visual sóbrio, em azul com detalhes em vermelho (o que exige atenção) e dourado (marca e filetes), nos temas claro e escuro, com botão de lua e sol.

Glossário

TERMO	SIGNIFICADO
Sua empresa (tenant)	Quem usa o sistema. Todos os dados pertencem a uma empresa, e uma nunca vê os dados da outra.
Empresa atendida	Para quem o processo é feito (na tela, "Empresa"). Tem **nome** e **número** (código interno). Guardada na tabela `cliente`.
Setor	Departamento. Cada setor define quais entregas pode fazer.
Entrega	O que pode ser entregue. Cada entrega está ligada a um fluxo, que vira o fluxo do processo.
Fluxo	Modelo de trabalho: conjunto de etapas e das transições permitidas entre elas.
Etapa	Um passo do fluxo. Pode ter prazo em dias, ser a inicial ou ser final.
Transição	Caminho permitido de uma etapa para outra. Só movimentos previstos são aceitos.
Processo	Um caso concreto em andamento num fluxo (contrato, alvará, licença etc.).
Responsável	Usuário encarregado do processo no momento. Recebe os avisos.

2. Arquitetura e tecnologias

O sistema é um **monolito modular**: um único backend dividido em módulos por assunto, o que é mais simples de operar do que microsserviços e permite separar partes depois, se for preciso.

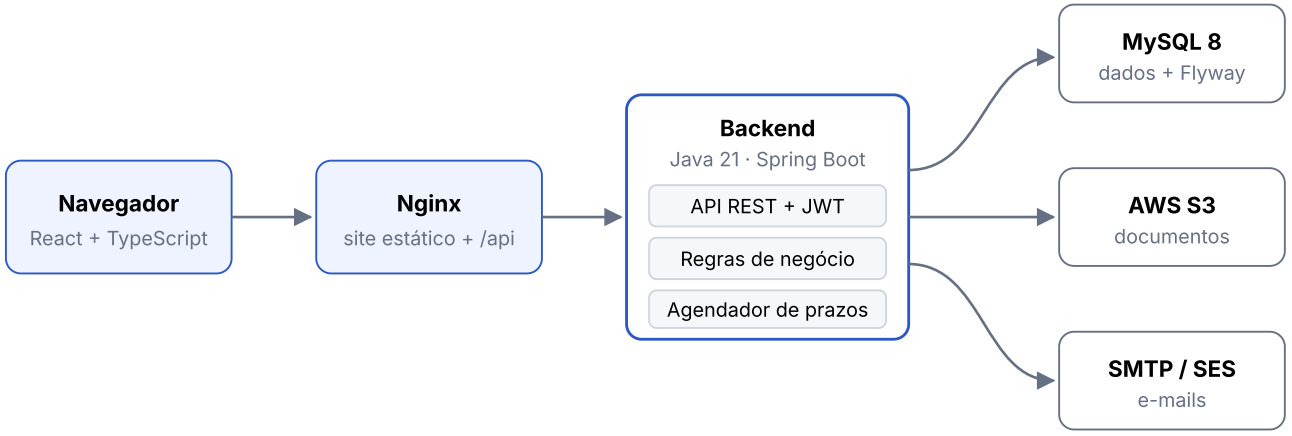


Figura 1 — Visão geral. O navegador só fala com o Nginx; o Nginx entrega o site e repassa `/api` ao backend.

Tecnologias

CAMADA	TECNOLOGIA	PAPEL
Interface	React 18, TypeScript, Vite, React Router	Telas, rotas, tema claro/escuro
Backend	Java 21, Spring Boot 3.3 (Web, Data JPA, Security, Validation, Mail)	API REST, regras, segurança
Banco	MySQL 8.4, Flyway	Dados e versionamento do esquema
Autenticação	JWT (jjwt), BCrypt	Login sem sessão no servidor
Arquivos	AWS S3 (SDK v2)	Documentos anexados
E-mail	Spring Mail (SMTP; AWS SES em produção)	Notificações por e-mail
Documentação da API	springdoc OpenAPI / Swagger UI	Referência interativa em `/swagger-ui.html`
Infraestrutura	Docker, Docker Compose, Nginx	Execução local e base para produção
Qualidade	JUnit 5, MockMvc, H2, GitHub Actions	Testes automáticos e CI

Organização do código

MÓDULO (BACKEND)	RESPONSABILIDADE
`seguranca`	Geração e validação do JWT, filtro de requisições, regras de acesso e CORS.
`usuario`	Login, cadastro de empresa (onboarding), usuários e papéis.
`fluxo`	Fluxos, etapas e transições por empresa.
`processo`	Núcleo do sistema: processos, movimentação, histórico, atribuição, cancelamento.
`documento`	Upload, download e remoção de arquivos, com armazenamento abstraído (S3).
`notificacao`	Avisos no sistema, envio de e-mail e agendador de prazos.
`comum`	Tratamento padronizado de erros e utilitários de data.

3. Como o sistema funciona

Esta seção percorre a jornada de uso, da primeira tela até o encerramento de um processo.

3.1 Primeiro acesso: cadastro da empresa

Na tela de login, *Cadastrar minha empresa* pede o nome da empresa, o nome do usuário, e-mail e senha (mínimo de 8 caracteres). Numa única operação o sistema cria a empresa, o primeiro usuário como **Administrador**, um **fluxo padrão**, o setor **Geral** e a entrega **Atendimento geral**, e já devolve a sessão. As empresas atendidas são cadastradas depois pelo administrador ou pelo gestor. Não existe usuário ou senha pré-cadastrados.

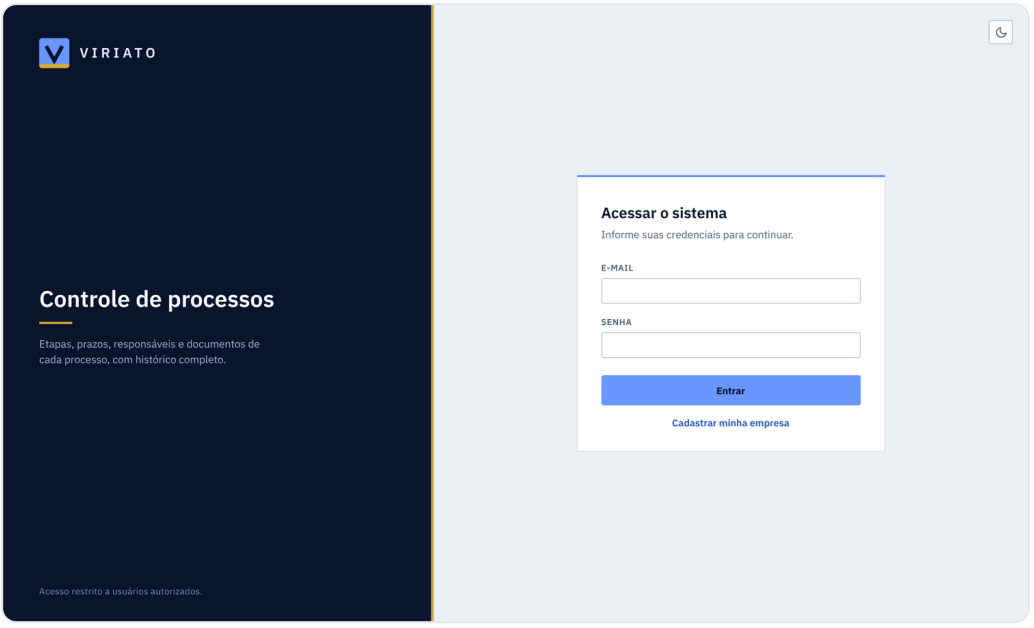


Figura 2 — Tela de login, com o botão de tema no canto superior direito.

3.2 Login e sessão

1. O usuário informa e-mail e senha. O sistema confere a senha (BCrypt) e verifica se o usuário e a empresa estão ativos.
2. Se estiver tudo certo, devolve um **token JWT** válido por 12 horas. Ele carrega o identificador do usuário, o da empresa e o papel.
3. O navegador guarda o token e o envia em cada chamada. Se o servidor responder 401, o usuário é deslogado.

A empresa de cada requisição vem **sempre do token**, nunca de algo que o usuário digite. É isso que sustenta o isolamento entre empresas.

3.3 Fluxos

Administradores e Gestores criam fluxos na tela *Fluxos*: informam as etapas em ordem, o prazo em dias de cada uma, qual é a inicial (exatamente uma) e quais são finais (ao menos uma). Regras validadas pelo sistema:

- mínimo de 2 etapas; todas com nome; prazo não negativo;

- uma etapa final não pode ter saída;
- pela tela, as etapas são ligadas em sequência (cada uma leva à seguinte). A API já aceita transições arbitrárias.

Um fluxo pode ser desativado (deixa de aceitar novos processos, mas os que já existem continuam normalmente) ou apagado, conforme as regras da seção 4.

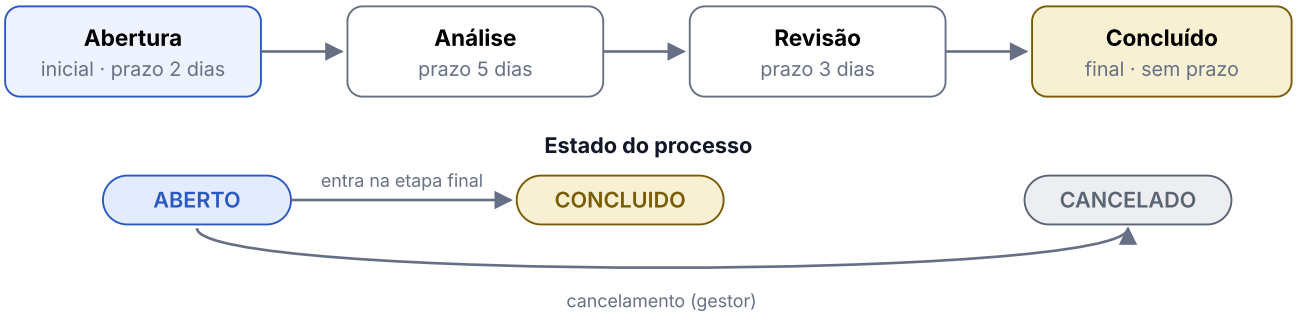


Figura 3 — Fluxo padrão criado com a empresa e os três estados de um processo.

3.4 Cadastros: empresas, setores e entregas

A página *Cadastros* reúne três listas, todas por empresa do sistema:

- **Empresas atendidas:** para quem os processos são feitos. Cada uma tem **número** e **nome**: o número é um código interno de 1 a 10 dígitos, que não pode repetir o de outra empresa atendida, e é ele que passa a ser o número dos processos da empresa. Administrador e gestor cadastram, alteram e apagam.
- **Entregas:** o que pode ser entregue. Cada entrega escolhe o fluxo que seus processos vão seguir.
- **Setores:** departamentos. Cada setor marca quais entregas ele faz.

Setores e entregas também são mantidos pelo administrador e pelo gestor. Qualquer item pode ser **desativado** (deixa de aparecer para novos processos, sem afetar os que já existem) ou **apagado**, conforme as regras da seção 4. Os nomes não se repetem dentro da empresa.

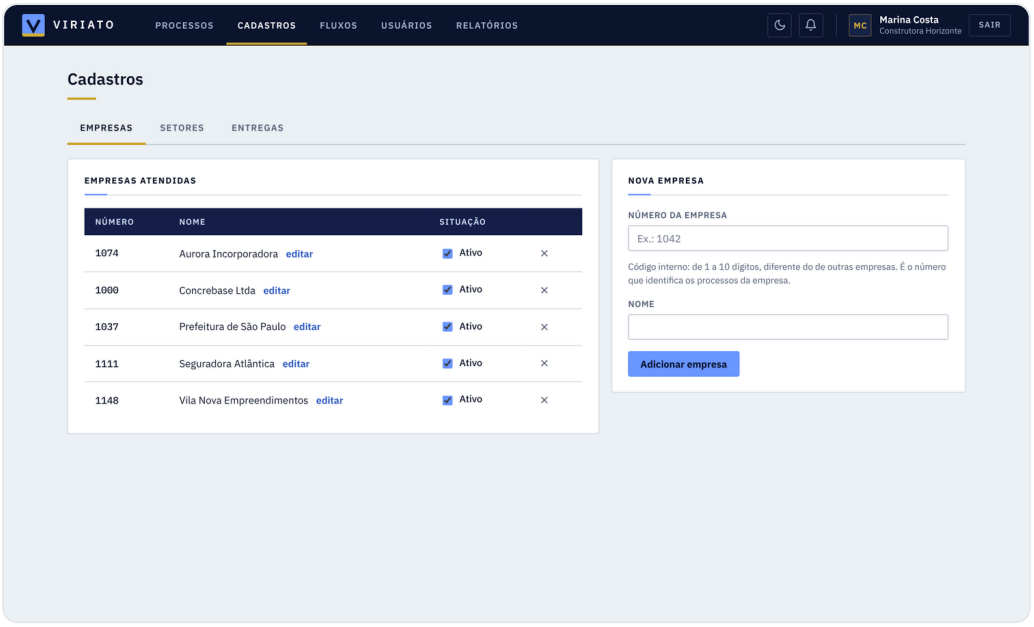


Figura 4 — Empresas atendidas, com número e nome; o número só aceita dígitos e o sistema recusa números repetidos.

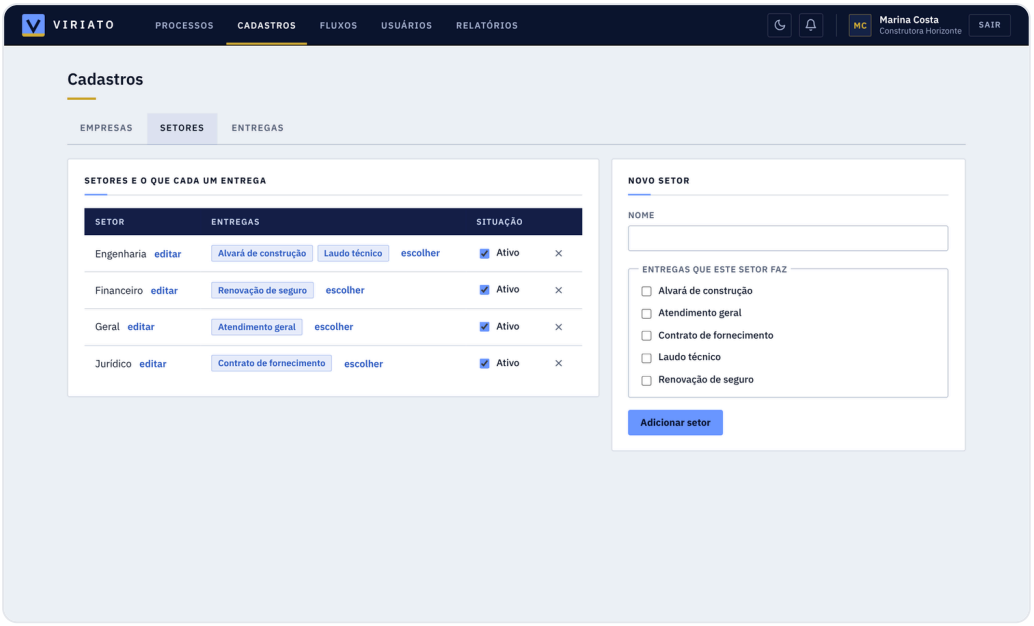


Figura 5 — Setores e as entregas que cada um faz; o botão *escolher* altera a lista.

3.5 Abrir e acompanhar processos

Qualquer usuário pode abrir um processo. O formulário pede, nesta ordem:

1. **Empresa** atendida;
2. **Departamento**: ao escolher, a lista seguinte mostra *somente as entregas que esse setor faz*;
3. **O que vai entregar** (a entrega), com a indicação do fluxo que será usado;
4. **Responsável**, entre os usuários ativos; vem preenchido com quem está abrindo.

Há ainda um campo opcional de observações. Não existe campo de título, de número nem de fluxo: o **título é gerado** (por exemplo *Laudo técnico — Construtora Alfa*) e o **fluxo vem da entrega**. Ao criar, o sistema:

1. confere que a empresa, o setor e a entrega são da sua empresa e estão ativos, que o setor realmente faz aquela entrega e que o fluxo da entrega está ativo;
2. coloca o processo na etapa inicial do fluxo e calcula o prazo (hoje + dias da etapa, fuso America/Sao_Paulo);
3. usa como número do processo o **número da empresa atendida** (por exemplo `1042`);
4. registra no histórico a ação *Criado* e avisa o responsável, se for outra pessoa.

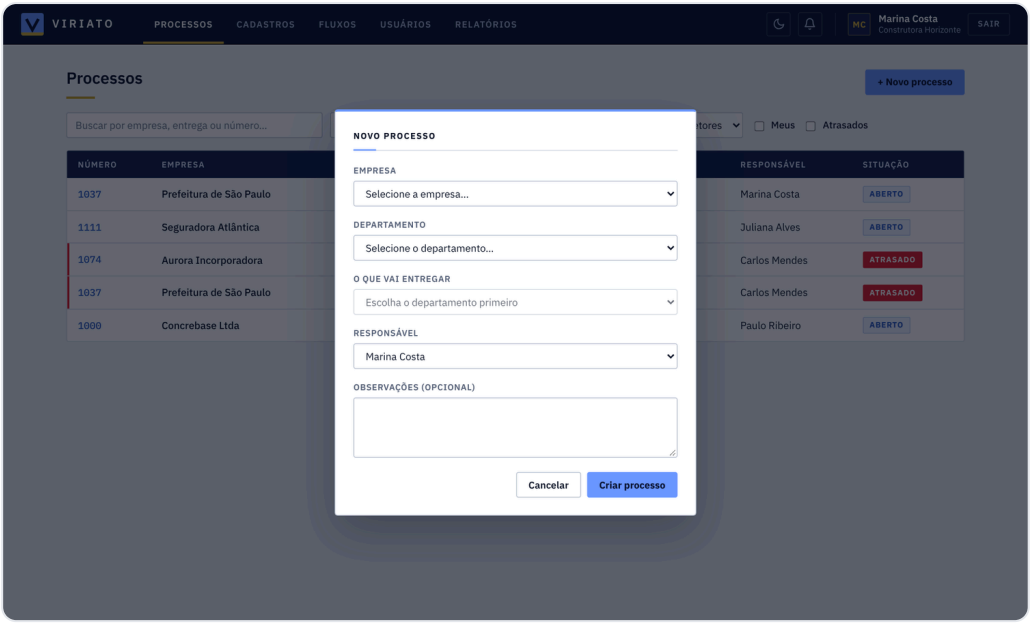


Figura 6 — Novo processo: a entrega só libera depois do departamento e mostra apenas o que ele faz.

A lista de processos mostra, nesta ordem, número, empresa, setor, entrega, prazo, responsável e situação (a etapa atual aparece no detalhe), e tem busca por empresa, entrega ou número, filtros por situação, empresa e setor, *Meus* (onde sou responsável) e *Atrasados*, com paginação. Um processo é considerado **atrasado** quando está aberto e o prazo da etapa já passou; isso é calculado na hora da consulta.

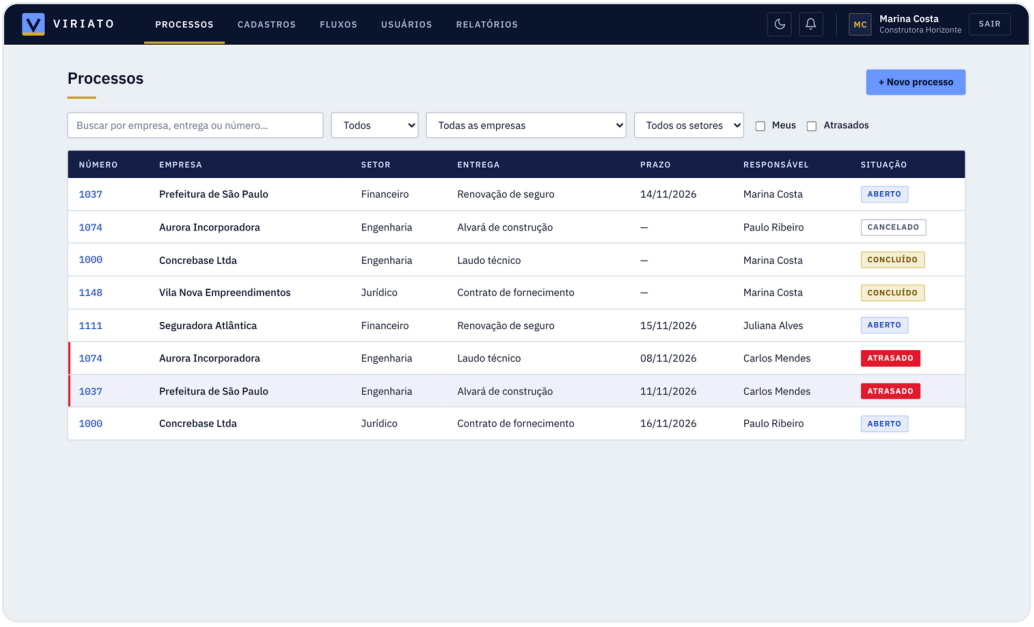


Figura 7 — Lista de processos com empresa, entrega, setor, filtros e selos de situação (tema claro).

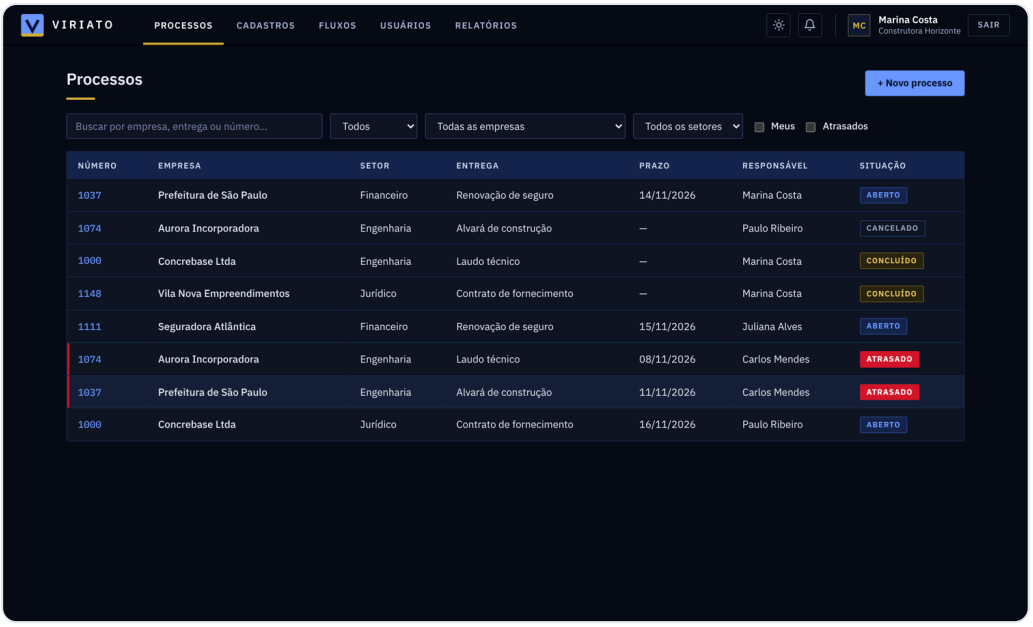


Figura 8 — A mesma tela no tema escuro, escolhido pelo botão de sol/lua no topo.

3.6 Movimentar um processo

No detalhe do processo aparecem os botões das etapas para as quais o fluxo permite avançar a partir da etapa atual. Ao avançar:

1. o processo precisa estar aberto e o usuário precisa poder mexer nele (administrador e gestor em qualquer um; usuário comum só nos seus; ver seção 4);
2. a transição precisa existir no fluxo; senão o sistema recusa com a mensagem *Transição não permitida pelo fluxo*;
3. a etapa muda, o prazo é recalculado e o controle de alerta é zerado;
4. se a etapa de destino for final, o processo vira **Concluído** e o prazo é removido;
5. a movimentação entra no histórico, com o comentário opcional, e o responsável é avisado.

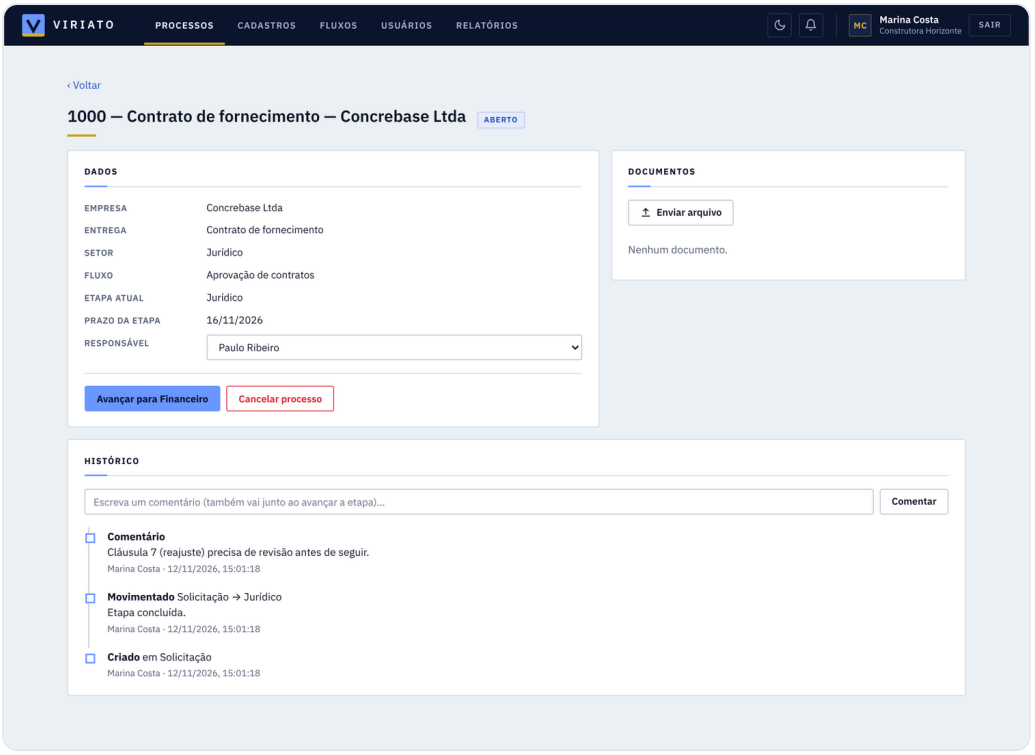


Figura 9 — Detalhe: empresa, entrega e setor, documentos, ações disponíveis e histórico em linha do tempo.

3.7 Documentos

Cada processo aceita anexos de até 25 MB por arquivo. O sistema sanitiza o nome do arquivo (remove caminhos e caracteres perigosos), grava no S3 com uma chave única por empresa e processo e criptografia no repouso (AES-256), e só então registra no banco. Se o registro falhar, o arquivo enviado é removido para não sobrar lixo no bucket. O **download passa pelo backend**, que confere a empresa antes de entregar o arquivo; não há links públicos.

3.8 Prazos e notificações

Uma tarefa agendada roda todos os dias às 08:00 (America/Sao_Paulo). Ela procura processos abertos, com responsável, cujo prazo vence em até 1 dia ou já venceu e que ainda não foram alertados naquela etapa. Para cada um, avisa o responsável (*Prazo próximo do vencimento* ou *Prazo vencido*) e marca como alertado. O resultado é **um alerta por etapa**; ele volta a valer quando o processo muda de etapa ou de responsável.

Cada notificação é gravada no sistema (sininho no topo, com contador de não lidas, atualizado a cada 30 segundos) e enviada por e-mail de forma assíncrona. O e-mail é *best-effort*: se o servidor de e-mail falhar, isso é registrado em log e a operação principal não é afetada.

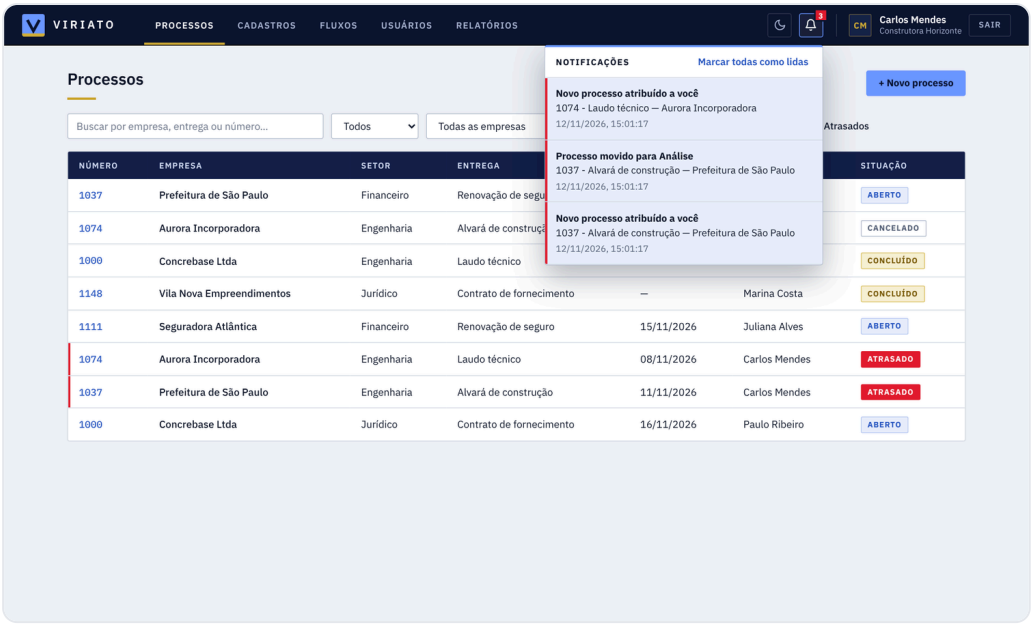


Figura 10 — Painel de notificações; as não lidas têm destaque e levam direto ao processo.

3.9 Relatórios

A aba *Relatórios* gera um PDF com os processos, e está aberta a todos os papéis. O que cada pessoa pode abranger é decidido pelo servidor, a partir do papel, e não pelo que a tela envia:

PAPEL	ABRANGÊNCIA DO RELATÓRIO
Administrador	Todos os setores, com a opção de filtrar por um setor.
Gestor	Somente o **próprio setor**. O filtro de setor fica travado, e a lista de responsáveis traz só quem é do setor. Pedir outro setor direto pela API é recusado (403). Gestor sem setor definido não consegue gerar relatório e recebe um aviso.
Usuário	Somente os **próprios processos** (aqueles em que é o responsável). O filtro de responsável fica travado nele mesmo.

Os filtros se combinam: **setor**, **responsável**, **empresa**, **período** (por data de abertura ou por data de encerramento) e **situação** (em andamento, concluídos, cancelados). Antes de gerar, a tela mostra uma **prévia** com os totais (total, em andamento, atrasados, concluídos e cancelados); o botão fica bloqueado se não houver processo, se a data inicial for depois da final ou se nenhuma situação estiver marcada. No período por encerramento, só entram processos concluídos ou cancelados, e a data considerada é a da última movimentação.

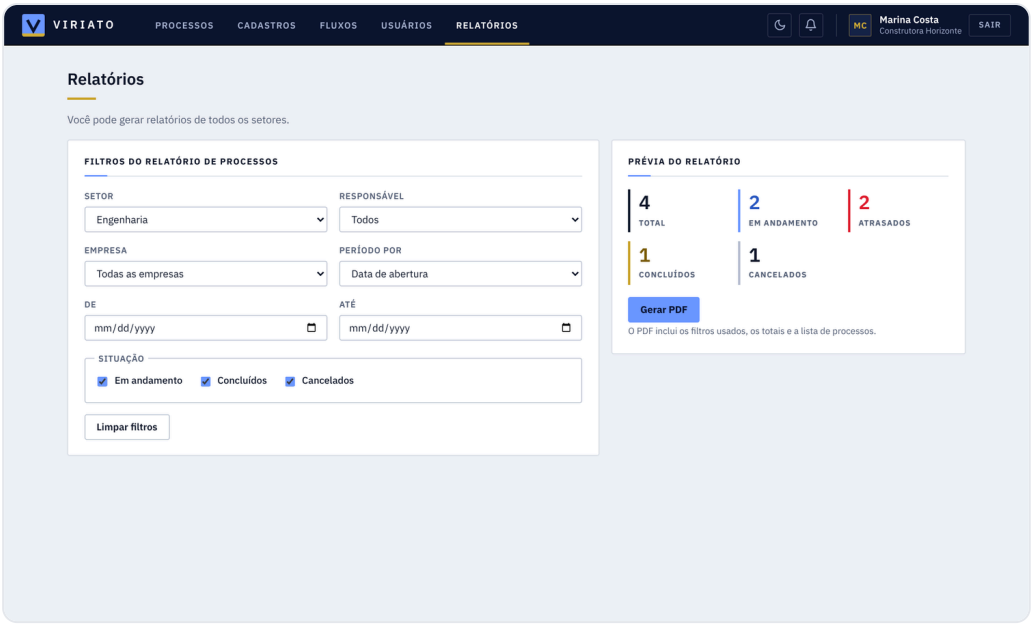


Figura 11 — Aba Relatórios: filtros à esquerda, prévia e botão de gerar à direita.

O PDF sai em A4 paisagem, na identidade visual do sistema: cabeçalho com a empresa, quem gerou, quando e a abrangência; a lista dos filtros usados; os totais; e a tabela com número, empresa, setor, entrega, responsável, data de abertura, data de encerramento e situação (o atrasado aparece em vermelho). O cabeçalho da tabela se repete em cada página, e o rodapé traz *Página X de Y*. Cada relatório comporta até 10.000 processos; acima disso o sistema pede para refinar os filtros.



NÚMERO	EMPRESA	SETOR	ENTREGA	RESPONSÁVEL	ABERTO EM	ENCERRADO EM	SITUAÇÃO
1037	Prefeitura de São Paulo	Financeiro	Renovação de seguro	Marina Costa	12/11/2026	—	EM ANDAMENTO
1074	Aurora Incorporadora	Engenharia	Alvará de construção	Paulo Ribeiro	12/11/2026	12/11/2026	CANCELADO
1000	Concrebase Ltda	Engenharia	Laudo técnico	Marina Costa	12/11/2026	12/11/2026	CONCLUÍDO
1148	Vila Nova Empreendimentos	Jurídico	Contrato de fornecimento	Marina Costa	12/11/2026	12/11/2026	CONCLUÍDO
1111	Seguradora Atlântica	Financeiro	Renovação de seguro	Juliana Alves	12/11/2026	—	EM ANDAMENTO
1074	Aurora Incorporadora	Engenharia	Laudo técnico	Carlos Mendes	12/11/2026	—	ATRASADO
1037	Prefeitura de São Paulo	Engenharia	Alvará de construção	Carlos Mendes	12/11/2026	—	ATRASADO
1000	Concrebase Ltda	Jurídico	Contrato de fornecimento	Paulo Ribeiro	12/11/2026	—	EM ANDAMENTO

Figura 12 — Primeira página de um relatório gerado pelo administrador, sem filtros.

4. Papéis e permissões

Todos os usuários da empresa **enxergam tudo**: processos de todos, documentos, histórico, cadastros, fluxos e a equipe (com papel e setor). O que muda é quem pode **alterar**.

AÇÃO	ADMINISTRADOR	GESTOR	USUÁRIO
Ver processos, cadastros, fluxos e equipe	**sim**	**sim**	**sim**
Abrir processo	**sim**	**sim**	**sim**
Movimentar, comentar, anexar e remover anexo, reatribuir	**em qualquer processo**	**em qualquer processo**	só nos processos em que é o responsável
Gerar relatório em PDF	**de todos os setores**	só do próprio setor	só dos próprios processos
Cancelar processo	**sim**	**sim**	**não**
Cadastrar e alterar empresas atendidas	**sim**	**sim**	**não**
Cadastrar e alterar setores e entregas	**sim**	**sim**	**não**
Apagar empresas, setores e entregas	**sim, se não houver processo em andamento ligado**	**sim, se não houver processo em andamento ligado**	**não**
Apagar fluxos	**sim, se nenhuma entrega o usa e não houver processo em andamento nele**	**sim, se nenhuma entrega o usa e não houver processo em andamento nele**	**não**
Criar e ativar/desativar fluxos	**sim**	**sim**	**não**
Adicionar funcionários	**com qualquer papel**	só com papel Usuário	**não**
Alterar o setor de um funcionário	**sim**	**não**	**não**
Alterar o papel de um funcionário	**sim**	**não**	**não**
Ativar ou desativar funcionário	**qualquer um**	só os de papel Usuário	**não**
Apagar funcionário	**qualquer um, menos a si mesmo; se não for responsável por processo em andamento**	só os de papel Usuário	**não**

Detalhes de comportamento:

- Na tela, quem não pode alterar algo não vê o botão nem o formulário; a página mostra o aviso *Somente consulta*. Além disso, o servidor recusa a ação mesmo que alguém tente chamá-la direto pela API.
- Recusas por papel (por exemplo usuário comum cadastrar empresa) devolvem HTTP 403. Recusas por regra de negócio (usuário comum mexer em processo alheio) devolvem HTTP 422 com uma mensagem em português.
- O administrador não consegue desativar nem rebaixar a si mesmo, para evitar ficar sem acesso.
- Gestor sem setor definido não gera relatório: o sistema avisa para pedir ao administrador que defina o setor.
- Recursos de outra empresa respondem 404, como se não existissem.
- **Apagar nunca leva processos junto.** Só processo *em andamento* impede apagar uma empresa, um setor, uma entrega, um fluxo ou um funcionário: o sistema recusa, informa quantos processos estão ligados e orienta a concluí-los ou cancelá-los (ou a desativar o cadastro). Processos *concluídos ou cancelados* não bloqueiam; eles continuam existindo, apenas sem o vínculo com o item apagado (a lista mostra "—"; o título gerado e o histórico mantêm a informação).
- Apagar uma entrega a remove da lista dos setores; apagar um setor deixa os funcionários dele sem setor.
- Um fluxo não é apagado se alguma entrega ainda o usa (a mensagem cita as entregas) nem se há processo em andamento nele. Ao apagar, suas etapas e transições saem junto; os processos encerrados ficam sem fluxo e sem etapa atual, e o histórico, que guarda os nomes das etapas, continua legível.
- Um funcionário responsável por processo em andamento só é apagado depois que esse processo for passado a outra pessoa; nos processos já encerrados ele simplesmente deixa de constar como responsável. Os avisos dele são removidos; o histórico permanece, com o autor indicado como *usuário removido*. Quem foi apagado deixa de conseguir entrar.
- Na tela, o botão **X** sempre pede confirmação, e a ação não pode ser desfeita.
- O usuário comum pode abrir um processo e atribuí-lo a qualquer colega ativo; a partir daí, só o responsável (ou um gestor) mexe nele.
- O gestor ativa e desativa apenas funcionários com papel Usuário; não mexe na situação do administrador nem de outros gestores. Um funcionário desativado deixa de conseguir entrar.

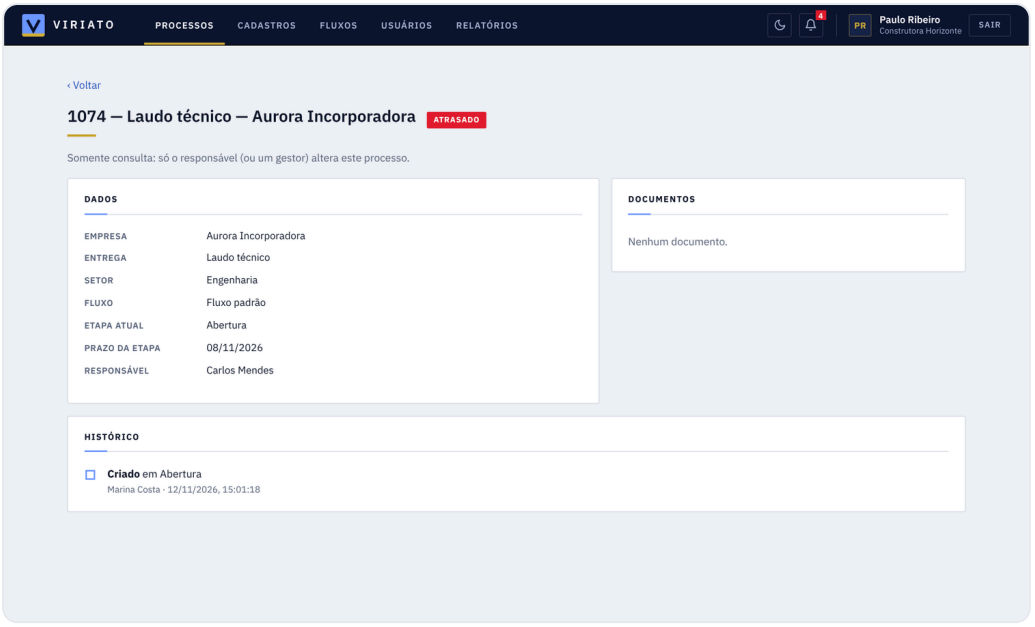


Figura 13 — Um usuário comum diante do processo de outra pessoa: vê tudo, sem botões de ação.

5. Modelo de dados

Todas as tabelas de negócio têm a coluna `tenant_id`, e toda consulta filtra por ela. O esquema é criado e versionado pelo Flyway, em cinco migrações: `V1` (base), `V2` (empresas atendidas, setores, entregas e setor do funcionário), `V3` (empresa, entrega e setor no processo) `V4` (processo encerrado pode ficar sem fluxo) e `V5` (número da empresa; o número do processo deixa de ser único).

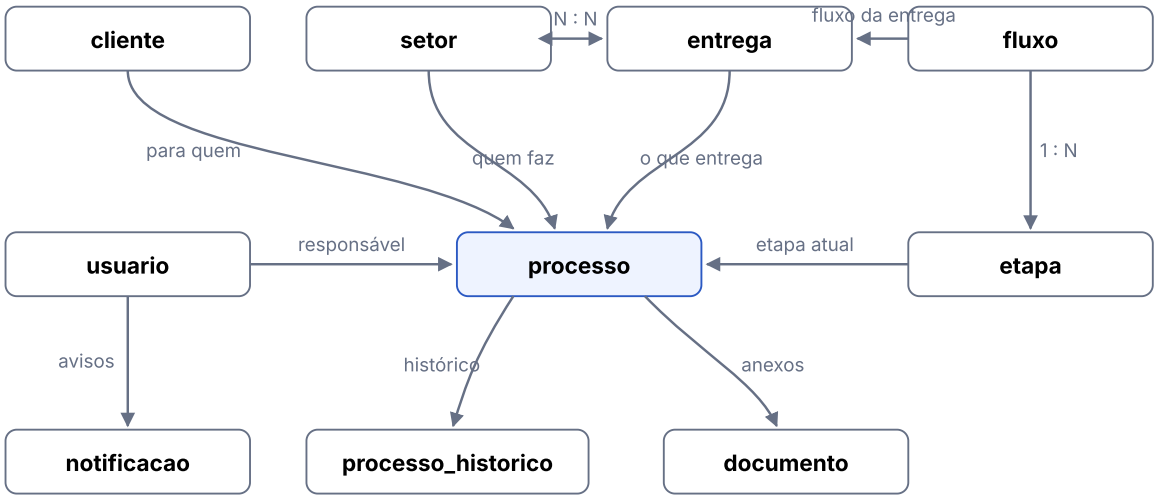


Figura 14 — Relações principais; as setas vão de quem é referenciado para quem o referencia. Para clareza, nem todas foram desenhadas: todas as tabelas de negócio apontam também para a empresa do sistema (`tenant`), e o funcionário aponta para o seu setor.

TABELA	CONTEÚDO E PONTOS IMPORTANTES
`tenant`	Empresa do sistema (quem usa o Viriato); flag `ativo`.
`usuario`	Nome, e-mail (único em todo o sistema), hash BCrypt da senha, papel, ativo e `setor_id` (opcional).
`cliente`	Empresa atendida: número (código interno de até 10 dígitos, único) e nome (único), mais a flag `ativo`. Empresas anteriores à V5 ficaram com o próprio identificador como número.
`setor`	Departamento: nome (único) e flag `ativo`.
`entrega`	Nome (único), `fluxo_id` e flag `ativo`.
`setor_entrega`	Liga cada setor às entregas que ele faz (muitos para muitos).
`fluxo`	Nome e flag `ativo`.
`etapa`	Nome, ordem, `prazo_dias` (opcional), flags `inicial` e `final_`.
`transicao`	Par de etapas (de, para), único; define os movimentos permitidos.
`processo`	Número (o da empresa; repete entre processos da mesma empresa), título (gerado), descrição, `cliente_id`, `entrega_id`, `setor_id`, fluxo, etapa atual, responsável, status, `prazo_etapa`, `prazo_alertado`, `campos_extras` (JSON livre em texto).
`processo_historico`	Ação (CRIADO, MOVIDO, COMENTARIO, ATRIBUIDO, CANCELADO), autor, etapas de origem e destino, comentário, data.
`documento`	Nome original, chave no S3, tipo, tamanho, quem enviou.
`notificacao`	Destinatário, título, mensagem, processo relacionado, lida.

6. Referência da API

Todas as rotas começam com `/api`. Fora as de autenticação, exigem o cabeçalho `Authorization: Bearer <token>`. A documentação interativa fica em `/swagger-ui.html` (42 rotas).

MÉTODO	ROTA	FUNÇÃO	QUEM
POST	`/auth/registrar-empresa`	Cria empresa, administrador e fluxo padrão; devolve sessão	público
POST	`/auth/login`	Autentica e devolve o token	público
GET	`/me`	Dados do usuário logado	todos
GET	`/usuarios`	Lista usuários da empresa	todos
POST	`/usuarios`	Adiciona funcionário (com setor opcional)	Admin (qualquer papel); Gestor (só Usuário)
PATCH	`/usuarios/{id}`	Altera papel, ativo ou setor	Admin (tudo); Gestor (só `ativo`, e só de quem é Usuário)
GET	`/clientes`, `/setores`, `/entregas`	Listas de empresas atendidas, setores (com suas entregas) e entregas (com o fluxo)	todos
POST, PATCH	`/clientes`, `/clientes/{id}`	Cria e altera empresa atendida (`numero` obrigatório, só dígitos, único; `nome`; ativo). Mudar o número atualiza o dos processos da empresa	Admin, Gestor
GET	`/relatorios/escopo`	O que o usuário pode abranger (todos os setores, o próprio setor ou os próprios processos)	todos
GET	`/relatorios/processos/resumo`	Totais dos processos que entrariam no relatório. Filtros: `usuarioId`, `setorId`, `clienteId`, `de`, `ate`, `referencia` (ABERTURA ou ENCERRAMENTO), `situacoes`	todos, dentro do papel
GET	`/relatorios/processos/pdf`	Gera o PDF do relatório, com os mesmos filtros	todos, dentro do papel
DELETE	`/clientes/{id}`, `/setores/{id}`, `/entregas/{id}`	Apaga o cadastro (recusa se houver processo em andamento ligado)	Admin, Gestor
DELETE	`/fluxos/{id}`	Apaga o fluxo, com etapas e transições (recusa se uma entrega o usa ou se há processo em andamento nele)	Admin, Gestor
DELETE	`/usuarios/{id}`	Apaga funcionário (recusa se for responsável por processo em andamento ou se for o próprio usuário)	Admin; Gestor (só Usuário)
POST, PATCH	`/setores`, `/setores/{id}`	Cria e altera setor (nome, ativo, lista de entregas)	Admin, Gestor

POST, PATCH	`/entregas`, `/entregas/{id}`	Cria e altera entrega (nome, fluxo, ativo)	Admin, Gestor
GET	`/fluxos`, `/fluxos/{id}`	Lista e detalha fluxos com etapas e transições	todos
POST	`/fluxos`	Cria fluxo	Admin, Gestor
PATCH	`/fluxos/{id}`	Ativa ou desativa	Admin, Gestor
GET	`/processos`	Lista com filtros: `status`, `etapaId`, `responsavelId`, `clienteId`, `setorId`, `entregaId`, `busca`, `atrasados`, `meus`, `pagina`, `tamanho`	todos
POST	`/processos`	Cria processo: `clienteId`, `setorId`, `entregaId` e `responsavelId` obrigatórios	todos
GET	`/processos/{id}`	Detalhe, próximas etapas possíveis e histórico	todos
POST	`/processos/{id}/avancar`	Move para outra etapa	Admin, Gestor; Usuário só se for o responsável
POST	`/processos/{id}/comentarios`	Adiciona comentário	todos
PUT	`/processos/{id}/responsavel`	Atribui ou remove responsável	Admin, Gestor; Usuário só se for o responsável
POST	`/processos/{id}/cancelar`	Cancela com motivo	Admin, Gestor
GET, POST	`/processos/{id}/documentos`	Lista e envia arquivo (multipart, campo `arquivo`)	todos
GET	`/documentos/{id}/download`	Baixa o arquivo	todos
DELETE	`/documentos/{id}`	Remove documento	Admin, Gestor; Usuário só se for o responsável
GET	`/notificacoes`, `/notificacoes/nao-lidas`	Últimas 50 e contador de não lidas	do próprio usuário
POST	`/notificacoes/{id}/ler`, `/notificacoes/ler-todas`	Marca como lida	do próprio usuário

Erros seguem sempre o formato `{"status": 422, "erro": "mensagem"}`; falhas inesperadas devolvem uma mensagem genérica e o detalhe fica só no log do servidor.

7. Segurança

O que já está implementado

- **Isolamento entre empresas:** o `tenant_id` vem só do token; toda consulta filtra por ele; acesso a recurso de outra empresa dá 404. Há testes automáticos cobrindo processos, comentários, documentos, download e uso de fluxo alheio.
- **Senhas:** guardadas com BCrypt; nunca retornam pela API.
- **Autenticação sem sessão:** JWT assinado (HS256) com validade de 12 horas. O sistema se recusa a iniciar com segredo menor que 32 bytes.
- **Acesso por padrão negado:** só `/api/**` autenticada, login e documentação são liberados; qualquer outra rota é bloqueada.
- **Arquivos:** nome sanitizado, chave única no S3, criptografia no repouso, download intermediado pelo backend com cabeçalho `nosniff`.
- **Validação de entrada:** tamanhos, e-mail, senha mínima e campos obrigatórios validados na API.
- **CORS** restrito às origens configuradas; em produção, com Nginx servindo site e API no mesmo domínio, nem é necessário.

Limitações conhecidas

> Esta lista existe para que nada seja descoberto tarde demais. Itens marcados com **(prioridade)** devem ser resolvidos antes de qualquer uso real.

1. **(prioridade) O token não pode ser revogado.** Desativar ou apagar um usuário, ou mudar seu papel, só passa a valer quando o token expira (até 12 horas), porque o filtro não consulta o banco a cada requisição. Quem foi desativado continua com o acesso que tinha nesse período.
2. **(prioridade) Sem limite de tentativas de login**, sem recuperação de senha e sem autenticação em dois fatores.
3. **(prioridade) Segredo padrão de desenvolvimento.** Existe um `JWT_SECRET` padrão para facilitar o uso local; em produção ele *precisa* ser trocado.
4. Upload sem lista de tipos permitidos e sem antivírus (limite de 25 MB por arquivo).
5. O token fica no `localStorage` do navegador. O React escapa o conteúdo, o que reduz o risco, mas uma falha de injeção de script exporia o token. Uma alternativa é cookie `HttpOnly`.
6. O e-mail é único em todo o sistema: uma pessoa não pode ter o mesmo e-mail em duas empresas.
7. O número do processo é o número da empresa atendida, então **não identifica um processo isoladamente**: processos da mesma empresa compartilham o número, e o que os distingue é o identificador interno, o título e o histórico. Processos criados antes dessa regra mantêm o número antigo (por exemplo `2026-000001`).
8. Todos da empresa veem todos os processos, por decisão de projeto; não há visibilidade restrita por equipe ou setor.

9. O responsável pode ser qualquer usuário ativo, não necessariamente do setor do processo.
10. O gestor escolhe o setor do funcionário ao adicioná-lo, mas depois só o administrador consegue alterá-lo.
11. Não há ferramentas de LGPD (exportar ou excluir dados de uma pessoa), nem registro de auditoria de login.

Limitações funcionais

- Apagar um funcionário não remove a sessão que ele já tenha aberta: ela continua válida até o token expirar (limitação 1 da seção 7).
- Os próprios processos não podem ser apagados (só concluídos ou cancelados); por isso um processo encerrado pode ficar com empresa, setor, entrega, fluxo ou responsável em branco depois que esses cadastros são apagados.
- Fluxos não podem ser editados depois de criados (só ativados ou desativados); a tela monta apenas transições em sequência.
- Os campos extras do processo são um JSON livre aceito pela API; ainda não há tela para preenchê-los.
- Processos criados antes da versão com empresa, entrega e setor continuam existindo, mas mostram esses campos em branco.
- Prazos em dias corridos, sem calendário de feriados.
- O PDF dos relatórios usa as fontes padrão do formato (Latin-1): letras fora dessa faixa podem não aparecer. Cada relatório comporta até 10.000 processos, e o período por encerramento usa a data da última movimentação do processo.
- Listas de usuários, fluxos e notificações não têm paginação (notificações mostram as 50 mais recentes).
- Data e hora do histórico aparecem no fuso do navegador.

8. Infraestrutura e implantação

Execução local

O `docker-compose.yml` sobe todo o ambiente com um comando (`docker compose up --build`):

SERVIÇO	FUNÇÃO	ENDEREÇO LOCAL
frontend	Nginx servindo o site e repassando `/api`	localhost:3000
backend	API Spring Boot	localhost:8080 (Swagger em `/swagger-ui.html`)
mysql	Banco MySQL 8.4, com volume persistente	interno
s3	S3 simulado (`adobe/s3mock`) só para desenvolvimento	localhost:9090
mailpit	Captura os e-mails enviados	localhost:8025

Configuração por variáveis de ambiente

VARIÁVEL	PARA QUÊ
`JWT_SECRET`	Segredo de assinatura (mínimo 32 bytes). **Obrigatório trocar em produção.**
`DB_URL` , `DB_USER` , `DB_PASSWORD`	Conexão com o MySQL.
`S3_BUCKET` , `S3_REGIAO`	Bucket real. Sem `S3_ENDPOINT` , usa a AWS com credenciais da função (IAM Role).
`MAIL_*`	Servidor SMTP (por exemplo AWS SES) e remetente.
`CORS_ORIGINS`	Origens permitidas.
`PRAZOS_CRON` , `PRAZOS_ANTECEDENCIA_DIAS`	Horário do alerta de prazo e antecedência em dias.

Caminho sugerido para produção na AWS

- **ECS Fargate** para backend e frontend (imagens dos Dockerfiles), atrás de um balanceador com HTTPS.
- **RDS MySQL** com backups automáticos.
- **S3** com bloqueio de acesso público e versionamento; a função do ECS com permissão só nesse bucket.
- **SES** para o envio de e-mails e um domínio verificado.
- Segredos no AWS Secrets Manager, logs no CloudWatch.

A integração contínua (GitHub Actions) compila e testa o backend e compila o frontend a cada envio.

9. Qualidade e verificações

O que foi verificado

VERIFICAÇÃO	RESULTADO
43 testes automáticos de integração (banco H2 em modo MySQL)	**passam**
Ciclo completo do processo: criar, avançar por todas as etapas, concluir, histórico	**coberto por teste**
Isolamento entre empresas (processo, comentário, documentos, download, fluxo alheio)	**coberto por teste**
Permissões por papel e transição fora do fluxo	**coberto por teste**
Cadastros: quem altera empresas, setores, entregas e funcionários; entrega só aceita se o setor a faz	**coberto por teste**
Apagar empresas, setores, entregas e funcionários: permissões, proteção do que está em uso, histórico preservado, isolamento entre empresas	**coberto por teste (7 testes)**
Número da empresa: obrigatório, só dígitos, único; número do processo igual ao da empresa; editar o número acompanha os processos; número livre de novo depois que a empresa é apagada	**coberto por teste (5 testes)**
Relatórios: abrangência por papel (administrador, gestor, usuário), filtros combinados, período por abertura e por encerramento, isolamento entre empresas e conteúdo do PDF	**coberto por teste (10 testes)**
Usuário comum vê tudo, mas não mexe em processo alheio (movimentar, comentar, anexar, remover, reatribuir, cancelar)	**coberto por teste**
Upload e download, com nome malicioso sanitizado	**coberto por teste**
Alerta de prazo: dispara uma vez só	**coberto por teste**
Migrações V1 a V5 e a aplicação contra MySQL 8 e S3 simulado reais	**executado, incluindo acentuação, permissões e isolamento**

(teste ponta a ponta via HTTP), incluindo as exclusões com chaves estrangeiras, a V5 aplicada sobre dados da versão anterior e a geração do PDF com várias páginas	
Interface em navegador automatizado: os três papéis (o que cada um vê e pode alterar), formulário de processo com entrega dependente do setor, colunas da lista, situação de funcionários, apagar cadastros e fluxos pelo X com confirmação, recusa de item em uso, concluir processo e então apagar, número da empresa e dos processos, aba Relatórios com download e leitura do PDF por papel, dois temas	**executado (103 verificações em 5 suítes, todas concluídas)**
Build do frontend com verificação de tipos	**passa**

Esse teste com MySQL real encontrou dois defeitos que o H2 não revelava (parâmetro de codificação da conexão e health check de e-mail derrubando a aplicação); ambos já foram corrigidos.

O que ainda não foi verificado

- O `docker compose up --build` completo, com as imagens do backend e do frontend rodando em contêiner (as peças foram testadas separadamente).
- AWS S3 e envio de e-mail reais (foram usados simuladores).
- Desempenho e carga, e comportamento com muitas empresas e processos.
- Navegadores além do Chromium, aparelhos móveis e acessibilidade formal.
- Testes automáticos do frontend (hoje só há o build e verificação manual automatizada).

Histórico de versões

COMMIT	MUDANÇA
`91d1473`	Estrutura inicial: backend, frontend, Docker, CI, testes e README
`591d047`	Alternância de tema claro/escuro com botão de lua e sol
`243ed8c`	Refinamento visual profissional
`4469f0f`	Correção: alinhamento dos campos extras no detalhe do processo
`6b83214`	Título do processo também abre o detalhe na lista
`6de61ef`	Primeira versão deste relatório
`2f0327d`	Backend: cadastros de empresas, setores e entregas; setor no usuário
`7d99fcd`	Backend: processo com empresa, entrega, setor e responsável
`0317dd6`	Frontend: cadastros, equipe com setor e modo consulta
`fbbca98`	Frontend: formulário e lista de processos com o novo modelo
`cb8de0b`	Relatório e README atualizados para cadastros e permissões
`1e64e8b`	Backend: gestor altera a situação do funcionário, não o setor
`f3281e9`	Frontend: tela de usuários conforme a nova regra do gestor
`a704418`	Frontend: colunas da lista de processos na ordem pedida
`343c1f0`	Relatório e README conforme a regra do gestor e as colunas
`5864164`	Backend: gestor também cadastra e altera empresas
`1ddd42c`	Backend: apagar empresas, setores, entregas e funcionários
`b5010d9`	Frontend: gestor cadastra empresas; botão apagar com confirmação
`72e95ef`	Textos de ajuda da tela conforme as novas permissões
`8f7fece`	Relatório e README com empresas pelo gestor e apagar cadastros
`d19009f`	Backend: só processo em andamento impede apagar
`20aa1c1`	Backend: apagar fluxos (migração V4)
`2015019`	Frontend: botão X no lugar do texto apagar
`6930597`	Frontend: apagar fluxos pela tela
`35d6a9c`	Relatório e README: nova regra de apagar e fluxos
`621e744`	Fontes IBM Plex instaladas localmente
`cfb7f77`	Frontend: identidade visual sóbria em azul, vermelho e dourado
`b16e12e`	Relatório com o novo visual do sistema
`be5d2bc`	Backend: empresa com número; número do processo é o da empresa (migração V5)
`ac2a919`	Frontend: cadastro de empresa com número e nome
`57af26d`	Backend: relatórios de processos em PDF por papel

`f4f37be`	Frontend: aba Relatórios

10. Próximos passos recomendados

Antes de qualquer uso real (segurança)

1. Validar o usuário a cada requisição (ou usar tokens curtos com renovação) para que desativar e mudar papel tenham efeito imediato.
2. Limite de tentativas de login e recuperação de senha por e-mail.
3. Trocar o segredo JWT e tirar valores padrão do ambiente de produção.
4. Lista de tipos de arquivo permitidos e verificação de vírus nos uploads.

Produto

1. Editor de fluxo com transições livres e edição de fluxos existentes.
2. Campos personalizados por fluxo, com tela de configuração.
3. Painel com indicadores (abertos, atrasados, tempo médio por etapa) e relatórios.
4. Prazos em dias úteis, com calendário de feriados por empresa.
5. Cobrança e planos para vender como SaaS, com limites por empresa.

Engenharia

1. Executar e validar o `docker compose` completo em CI.
2. Testes automáticos do frontend e testes de ponta a ponta.
3. Paginação nas listagens restantes e numeração de processo por empresa.

Apêndice — como acessar

Não há usuário ou senha pré-definidos. Depois de subir o sistema, abra a aplicação, clique em **Cadastrar minha empresa** e crie o seu acesso; ele já nasce como Administrador. Para abrir o primeiro processo, cadastre antes ao menos uma empresa atendida em *Cadastros → Empresas*; o setor Geral e a entrega Atendimento geral já vêm prontos. Os usuários e as empresas mostradas nas capturas deste relatório foram dados de demonstração criados num ambiente temporário e não fazem parte do código.